

Do attack-derived models predict where patients are harmed? A first validation of an ATT&CK-based clinical-impact model against coded harm

2026-09-20 (working note, version 0.1.0)

Abstract

Threat models built on MITRE ATT&CK reason about attacker behaviour on IT, not about which patients are harmed. We ask, for the first time to our knowledge, whether an ATT&CK-based clinical-impact model’s predicted distribution of harm across clinical services matches a corpus of *real coded patient harm* from hospital ransomware incidents (CIPHER: 128 high-severity records). To avoid circularity, the predicted profiles are built *without* CIPHER — a uniform ATT&CK-null and the model’s Neprash-anchored “assumed” degradation — and CIPHER is held out as ground truth. The real harm profile is pharmacy- and laboratory-heaviest (pharmacy 30.7%, laboratory 27.3%, EHR 21.6%, imaging 20.5%), whereas the model’s assumed profile is EHR-heaviest: it over-predicts EHR by +8.5 points and under-predicts pharmacy by -6.3 points, and needs a larger reporting-bias to reconcile ($\gamma = 0.60$) than even a uniform guess ($\gamma = 0.35$). Small sample size means neither profile is formally rejected, so the honest conclusion is not "the model is wrong" but "the model’s clinical-service resolution is not validated by real harm, and points the wrong way." The contribution is the validation itself, and the CIPHER overlay that supplies the clinical resolution ATT&CK lacks — not a new statistical method.

1 Design

CIPHER codes real patient harms by clinical specialty, technical domain, severity and onset timing. We map its four technical domains with a modelled counterpart (Health Records $\rightarrow$ EHR, Laboratory Systems $\rightarrow$ laboratory, ePrescribing $\rightarrow$ pharmacy, Imaging $\rightarrow$ imaging) and take the high-severity (impact ≥ 7) per-service counts as the observed profile (88 records; the large unmodelled residual is reported, not folded in). The predicted profiles use only model inputs independent of CIPHER: a *uniform* profile (the honest ATT&CK null, since ATT&CK has no clinical-service signal) and the model’s *assumed* degradation, set from the Neprash aggregate. This held-out design pre-empts training-on-test.

2 Comparison

We report the total-variation distance to the observed profile, an exact Monte-Carlo multinomial goodness-of-fit p -value (valid at small counts), and the *reconciling* γ : the least bounded per-domain underreporting that would place the predicted profile inside CIPHER’s partial-identification share intervals. A small γ means the model is close; a large γ means a real gap that only heavy reporting bias could explain.

Table 1: Fit of each CIPHER-independent predicted profile to the observed harm profile at $\tau = 7$.

Predicted profile	Total variation (%)	MC p	$\chi^2 p$	Reconciling γ
Uniform (ATT&CK null)	8.0	0.502	0.484	0.35
Assumed (model)	9.2	0.281	0.277	0.60

Table 2: Assumed profile vs. observed harm, per service (percent), with CIPHER mean clinical-impact score.

Service	Predicted (%)	Observed (%)	Residual (pp)	CIPHER mean impact
ehr	30.1	21.6	+8.5	5.42
laboratory	24.4	27.3	-2.9	7.12
pharmacy	24.4	30.7	-6.3	5.41
imaging	21.1	20.5	+0.7	6.73

3 Result

Neither predicted profile is rejected at $\tau = 7$ (Monte-Carlo $p = 0.502$ uniform, $p = 0.281$ assumed): with 88 records across four services the test has little power, which we state plainly rather than read as agreement. The informative signals are directional (Table 2): the assumed profile over-predicts EHR by +8.5 points and under-predicts pharmacy by -6.3 points, and its reconciling $\gamma = 0.60$ exceeds the uniform null’s 0.35 (Table 1). In other words, the model’s clinical-service differentiation does not beat a uniform guess against real harm, and it emphasises the wrong service. This is the first such calibration check for an ATT&CK-based clinical model, and it motivates the CIPHER overlay — an empirical per-service specialty, severity and onset-timing layer — as the clinical resolution ATT&CK cannot supply on its own.

4 Limitations

CIPHER is a convenience sample of reported harms: selection and reporting bias, no denominator, English-language and severe-harm skew. The comparison tests consistency with *this corpus*, not population truth; the reconciling γ makes the reporting-bias assumption explicit rather than hidden. Counts are small, so power is low and no strong rejection is claimed. Coding is single-label and the ATT&CK→service mapping is coarse; the unmodelled residual is large. This is a validation and an overlay resource, honestly scoped — not a new statistical method and not a population estimate.

Reproducibility. Predicted profiles are CIPHER-independent; the Monte-Carlo test uses a fixed seed; all numbers are generated from committed tables under a provenance manifest over the pinned ATT&CK bundle and CIPHER.